GRC ASSESSMENT REPORT

ICU IT Environment - NIST Cybersecurity Framework Assessment

Northview Regional Medical Center

Organization	Northview Regional Medical Center
Document Type	GRC Risk & Control Assessment Report — Full Report
Assessment Framework	NIST Cybersecurity Framework (CSF) v1.1
Scope	ICU IT Environment — Systems, Devices, EHR, Vendors
Assessment Period	Q1 2025 — January 6 to March 28, 2025
Overall Risk Posture	**HIGH RISK**
Overall Maturity	**Level 1 — Ad Hoc | Score: 1.2 / 5.0**
Prepared By	GRC Analyst — ICU IT Audit Team
Report Version	v1.0 — Final | March 28, 2025
Distribution	CISO, CIO, CMO, CFO, Board Risk Committee

This document contains sensitive security findings and is classified CONFIDENTIAL. Unauthorized distribution is prohibited.

SECTION 1

Executive Summary

Overall Posture: HIGH RISK | Maturity: Level 1 — Ad Hoc

SECTION 1 — EXECUTIVE SUMMARY

To: CISO, CIO, CMO, CFO, and Board Risk Committee
From: GRC Analyst — ICU IT Audit Team
Re: GRC Assessment of ICU IT Environment — Northview Regional Medical Center
Date: March 28, 2026 | Classification: CONFIDENTIAL

1.1 Organization Overview

Northview Regional Medical Center is a 200-bed regional hospital providing acute care services including an Intensive Care Unit (ICU) with network-connected biomedical devices. The hospital operates a hybrid IT infrastructure combining on-premises systems with Microsoft Azure cloud workloads, and manages Electronic Health Records (EHR) for its patient population. The hospital handles Protected Health Information (PHI), Personally Identifiable Information (PII), and payment data, and engages third-party vendors for laboratory and billing services.

As a Covered Entity under HIPAA, Northview Regional Medical Center bears full regulatory responsibility for the security of ePHI across its environment and the environments of its Business Associates. The ICU — the subject of this assessment — represents the hospital's highest-risk IT zone due to the convergence of life-critical connected devices, sensitive patient data, and historically underinvested security controls.

1.2 Scope of Assessment

This assessment evaluated the ICU IT environment against the NIST CSF v1.1 across all five core functions: Identify, Protect, Detect, Respond, and Recover. Conducted between January 6 and March 28, 2025, the engagement encompassed:

Systems Reviewed: EHR platform, ICU biomedical devices, Active Directory/IAM, network infrastructure, hybrid cloud, lab and billing third-party systems, ICU clinical workstations

Departments Included: ICU, IT, Information Security, Biomedical Engineering, HIM, Finance, HR, Legal & Compliance

Data Types: Electronic Protected Health Information (ePHI), PII, payment data

Methods: Staff interviews, policy review, system configuration observation, access log sampling, network topology review, vendor contract review

1.3 Overall Security Posture

OVERALL SECURITY POSTURE: HIGH RISK

11 of 14 risks rated High | 0 of 14 controls rated Effective | Maturity: Level 1 — Ad Hoc

The ICU IT environment presents a HIGH RISK security posture. This is determined by three compounding conditions: a near-complete absence of foundational governance structures, systemic failure of technical controls across all five NIST CSF functions, and direct exposure to HIPAA regulatory enforcement risk. The combination of absent real-time detection, unencrypted PHI backups, unenforced MFA, and a flat network connecting administrative endpoints to life-critical ICU devices creates conditions in which a single successful phishing attack or ransomware deployment could simultaneously compromise patient data, disrupt clinical operations, and endanger lives.

11	0	7/10	1.2/5
HIGH RISKS of 14 identified	EFFECTIVE CONTROLS of 14 evaluated	HIPAA NON-COMPLIANT of 10 standards reviewed	MATURITY SCORE Level 1 — Ad Hoc

1.4 Top 5 Critical Risks

#01 No Network Segmentation Between ICU Devices and Hospital IT Network [RR-11]

Why it matters: A single compromised administrative endpoint has an unobstructed network path to ventilators, cardiac monitors, and infusion pumps. Ransomware on any hospital workstation could propagate to life-critical ICU devices with no architectural barrier. This is a direct patient safety risk.

Required action: *Immediate VLAN segmentation of ICU device network — Phase 1, P1-04.*

#02 Multi-Factor Authentication Not Enforced on EHR System [RR-04]

Why it matters: All clinical and administrative users authenticate to the EHR with username and password only. Credential theft via phishing provides immediate, unrestricted access to patient records. This is the most exploitable single access control gap in the environment.

Required action: *MFA enforcement for all EHR users — Phase 1, P1-01. 30-day deadline.*

#03 No SIEM or Real-Time Threat Detection Capability [RR-08]

Why it matters: The hospital cannot detect an active breach, ransomware propagation, or insider threat in real time. Without detection capability, the organization cannot respond to what it cannot see. Average dwell time for an undetected healthcare breach exceeds 200 days.

Required action: *SIEM deployment — Phase 2, P2-01. Begin procurement immediately.*

#04 PHI Backup Volumes Not Encrypted at Rest [RR-07]

Why it matters: Under HIPAA, loss or unauthorized access to an unencrypted backup volume is a reportable breach with no safe harbour. This compliance liability can be eliminated with immediate action and creates zero operational disruption to remediate.

Required action: *AES-256 encryption on all backup volumes — Phase 1, P1-05. Within 30 days.*

#05 Incident Response Plan Outdated and Untested [RR-09]

Why it matters: The current IRP does not address ransomware, medical device compromise, or cloud incidents, and has not been tested in 24+ months. An untested IRP during an active ransomware event leads to uncoordinated response and failure to meet the HIPAA 60-day breach notification requirement.

Required action: *IRP revision and tabletop exercise — Phase 1 (P1-03) and Phase 2 (P2-05).*

1.5 Strategic Recommendations for Leadership

Elevate cybersecurity to a board-level governance issue

The risks in this report are not IT problems — they are enterprise risks with direct patient safety, regulatory, and organizational viability implications. The CISO should report to the board quarterly with a defined risk dashboard. A standing executive risk committee should be chartered within 30 days.

Fund the Phase 1 remediation plan without delay

Phase 1 requires an estimated $15,000–$40,000. Compare this against a single HIPAA enforcement action (up to $1.9M per violation category) or a ransomware recovery event (average healthcare sector cost: $1.3M). The return on investment for Phase 1 remediation is existential, not marginal.

Treat this assessment as the baseline, not the destination

This report documents where the organization is today. Sustainable security requires ongoing governance: quarterly risk reviews, annual assessments, continuous monitoring, and a GRC program with defined ownership and accountability.

Conclusion

The ICU IT environment at Northview Regional Medical Center is operating at a level of cybersecurity risk that is inconsistent with the obligations of a regulated healthcare organization and the expectations of the patients whose lives depend on the systems reviewed. The findings in this report are serious — but they are remediable. The organization has the opportunity to substantially reduce its risk exposure within 90 days through focused, prioritized action. Inaction is not a neutral position. In the current threat environment, inaction is a decision to accept consequences that may include regulatory enforcement, operational disruption, reputational damage, and patient harm.

SECTION 2

Scope Definition

Systems | Departments | Timeline | Assumptions | Exclusions

SECTION 2 — SCOPE DEFINITION

This section defines the boundaries of the GRC assessment conducted at Northview Regional Medical Center. Professional auditors establish scope rigorously to ensure findings are traceable, conclusions are defensible, and the assessment can be reproduced or extended in future audit cycles.

2.1 Systems & Assets Reviewed

System / Asset	Description	Classification
EHR Platform	Centralized Electronic Health Record system for patient data entry, retrieval, and care coordination. Hosted on hybrid on-premises and cloud infrastructure.	**Critical / PHI**
ICU Biomedical Devices	Network-connected clinical devices including ventilators, cardiac monitors, infusion pumps, and patient monitoring systems. Managed by Biomedical Engineering.	**Critical / Patient Safety**
Active Directory / IAM	Identity and Access Management infrastructure governing authentication and authorization for all hospital systems. On-premises deployment.	**Critical / PHI**
Hospital Network Infrastructure	Core switching, routing, firewalls, and wireless infrastructure supporting clinical and administrative environments.	**Critical**
Cloud Environment (Hybrid)	Microsoft Azure-hosted workloads including EHR backup, administrative applications, and communication services.	**High / PHI**
Lab Information System (LIS)	Third-party laboratory system integrated with EHR. Managed by external lab vendor with PHI data exchange.	**High / PHI**
Billing & Revenue Cycle System	Third-party billing platform processing payment data and PHI. Managed by external billing vendor.	**High / PHI / PCI**
ICU Clinical Workstations	End-user devices in the ICU used by clinical staff to access EHR and biomedical device interfaces.	**High / PHI**
Email & Communication Systems	Microsoft 365 environment used for internal and external communication. Cloud-hosted.	**Medium**

2.2 Departments & Functions Included

Department / Function	Scope Rationale
ICU / Intensive Care Unit	Primary audit focus. All connected devices, workstations, EHR access, and clinical workflows within the ICU reviewed.
Information Technology (IT)	Responsible for infrastructure, access management, patching, and cloud operations. Full scope included.
Information Security	Responsible for policy, monitoring, and incident response. Full scope included.
Biomedical Engineering	Responsible for medical device management and patching. Included due to ICU device scope.
Health Information Management (HIM)	Responsible for EHR governance and PHI handling. Included for access control and data governance review.
Finance & Revenue Cycle	Included due to third-party billing vendor relationship and payment data handling.
Human Resources (HR)	Included for user provisioning/de-provisioning process review and workforce security training governance.
Legal & Compliance	Consulted for HIPAA obligations, vendor contract review, and breach notification requirements.

2.3 Assessment Period & Timeline

Parameter	Details
Assessment Period	Q1 2025 — January 6, 2025 to March 28, 2025
Planning & Scoping	January 6 – January 17, 2025 (2 weeks)
Evidence Collection	January 20 – February 14, 2025 (4 weeks)
Analysis & Testing	February 17 – March 7, 2025 (3 weeks)
Reporting & Review	March 10 – March 28, 2025 (3 weeks)
Evidence Methods	Staff interviews, policy review, system configuration inspection, access log sampling, network topology review, vendor contract review
Framework	NIST Cybersecurity Framework (CSF) v1.1 — Five Core Functions: Identify, Protect, Detect, Respond, Recover

2.4 Assumptions

The following assumptions were made during the assessment. Findings should be interpreted in the context of these constraints.

- This assessment is based on documentation provided by hospital staff, staff interviews, and system observation — it does not constitute a technical penetration test or vulnerability scan.
- Findings reflect the state of the ICU IT environment as observed during Q1 2025 and may not capture changes made after March 28, 2025.
- The assessment assumes that information provided by hospital staff and management is accurate and provided in good faith.

- Access to some system configurations was facilitated by IT staff — configurations reviewed were assumed to reflect live system state.
- Third-party vendor environments were assessed through contract review and questionnaire only — no direct assessment of vendor infrastructure was conducted.
- The hospital is assumed to be a Covered Entity under HIPAA with full obligations under the Privacy Rule, Security Rule, and Breach Notification Rule.

2.5 Out of Scope

The following areas are explicitly excluded from this assessment. Exclusions do not imply these areas are low risk — they reflect the agreed boundaries of this engagement.

- Emergency Department, Surgical, and all non-ICU clinical departments — a separate assessment is recommended.
- Physical security of clinical areas beyond ICU server room and workstation access.
- Direct technical assessment or penetration testing of third-party vendor environments.
- Financial systems audit beyond the billing vendor relationship review.
- Patient safety device clinical efficacy — biomedical device assessment is limited to cybersecurity and network connectivity.
- Prior audit periods — this assessment covers Q1 2025 only and does not opine on historical control adequacy.

SECTION 3

NIST CSF Mapping

Identify | Protect | Detect | Respond | Recover

SECTION 3 — NIST CSF MAPPING & FINDINGS

The following assessment maps identified control gaps and security deficiencies to the five core functions of the NIST Cybersecurity Framework (CSF). Each finding is linked to a corresponding Risk Register entry (RR-XX) for traceability.

IDENTIFY

Asset Management | Risk Assessment | Supply Chain Risk

CONTROL GAPS IDENTIFIED

Finding / Gap	Risk Ref.	Risk Rating
No formal ICU device asset inventory (hardware, firmware, network location)	RR-01	High
No organizational risk register — risks are undocumented and unassigned	RR-02	High
Third-party vendor security posture not assessed or documented	RR-03	High
No data flow mapping for PHI across EHR, lab systems, and billing vendors	RR-03	High

CONTROL EFFECTIVENESS ASSESSMENT

Asset management is ad hoc. There is no CMDB, no formal risk register, and no vendor risk program. The organization cannot adequately protect what it has not identified. Maturity: Level 1 – Ad Hoc.

PROTECT

Access Control | Awareness | Data Security | Maintenance | Protective Technology

CONTROL GAPS IDENTIFIED

Finding / Gap	Risk Ref.	Risk Rating
MFA not enforced for EHR access across clinical and administrative users	RR-04	High
RBAC enforcement is weak — access not revoked upon role changes or termination	RR-05	High

Medical devices running EOL firmware with unpatched known vulnerabilities	RR-06	High
Backup data stored unencrypted at rest (on-prem and cloud)	RR-07	High
No network segmentation between ICU device network and hospital IT network	RR-11	High
Security awareness training not role-specific or current for clinical staff	RR-12	Medium
Physical server room access logs not reviewed or retained systematically	RR-13	Medium
No hardening baseline applied to cloud infrastructure	RR-14	Medium

CONTROL EFFECTIVENESS ASSESSMENT

Protective controls exist in name only in several areas. MFA is partially deployed but not enforced. RBAC policies exist but are not operationalized. Encryption is applied in transit but not at rest for backups. Network segmentation is absent in the ICU environment. Overall effectiveness is Weak to Partial. Maturity: Level 2 – Developing.

DETECT

Anomalies & Events | Security Monitoring | Detection Processes

CONTROL GAPS IDENTIFIED

Finding / Gap	Risk Ref.	Risk Rating
No SIEM or centralized log aggregation — event logs are siloed and unmonitored	RR-08	High
No correlation rules, alert tuning, or anomaly detection in place	RR-08	High
EHR access logs exist but are not reviewed on a scheduled or automated basis	RR-08	High

CONTROL EFFECTIVENESS ASSESSMENT

Detection capability is critically deficient. The hospital has no ability to identify a breach, insider threat, or ransomware propagation in real time. Without SIEM and log correlation, dwell time for attackers could extend to weeks or months before discovery. Maturity: Level 1 – Ad Hoc.

RESPOND

Response Planning | Communications | Analysis | Mitigation

CONTROL GAPS IDENTIFIED

Finding / Gap	Risk Ref.	Risk Rating
Incident Response Plan is outdated — does not address ransomware or cloud incidents	RR-09	High
No tabletop exercises or incident drills conducted in the past 24 months	RR-09	High

No defined escalation path or communication plan for regulators and patients in a breach	RR-09	**High**

CONTROL EFFECTIVENESS ASSESSMENT

The organization has a documented IRP on paper, but it is materially outdated and untested. Clinical staff and IT teams have not participated in simulated incident scenarios. There is no clear owner for incident command during an active breach. Control effectiveness: Weak. Maturity: Level 1 – Ad Hoc.

RECOVER

Recovery Planning | Improvements | Communications

CONTROL GAPS IDENTIFIED

Finding / Gap	Risk Ref.	Risk Rating
No documented RTO or RPO for ICU systems, EHR, or network infrastructure	RR-10	**High**
Backup restoration tested annually only — last test resulted in partial failure	RR-10	**High**
No recovery playbooks specific to ransomware, device compromise, or cloud failure	RR-10	**High**

CONTROL EFFECTIVENESS ASSESSMENT

Recovery capability is inadequate for a healthcare environment. Without defined RTO/RPO targets and regularly validated backups, the hospital risks extended downtime that directly impacts patient care continuity. Control effectiveness: Weak. Maturity: Level 1 – Ad Hoc.

SECTION 4

Risk Register

14 Identified Risks | 11 High | 2 Medium | 1 Low

SECTION 4 — RISK REGISTER

The table below documents all identified risks, mapped to their corresponding NIST CSF function, assessed for likelihood and impact, rated accordingly, and paired with prioritized recommendations. Risk ratings are determined using a qualitative likelihood × impact matrix.

Risk Rating Methodology: High = Likelihood (High) + Impact (High) — immediate threat to patient safety, PHI, or operational continuity. Medium = Likelihood (Med) + Impact (Med/High) — significant exposure requiring planned remediation within 90 days. Low = Likelihood (Low) + Impact (Low/Med) — address within 6–12 months.

Risk ID	Description	NIST Function	Likelihood	Impact	Risk Level	Recommendation
RR-01	No formal ICU device inventory — medical devices (ventilators, infusion pumps, cardiac monitors) not catalogued with firmware version, network location, or ownership.	Identify (ID.AM-1)	**High**	**High**	**High**	Implement automated asset discovery (e.g., Claroty, Medigate). Establish and maintain a live CMDB for all biomedical and IT assets within 30 days.
RR-02	Absence of a formal organizational risk register — risks are not documented, rated, tracked, or assigned to accountable owners.	Identify (ID.RA-1)	**High**	**High**	**High**	Establish a GRC risk register. Assign risk owners at department head level. Schedule quarterly review cycle.
RR-03	Third-party lab and billing vendors lack documented security assessments or contractual security obligations beyond the BAA.	Identify (ID.SC-2)	**High**	**High**	**High**	Conduct vendor risk assessments within 60 days. Enforce security addenda in all vendor contracts. Require annual SOC 2 Type II attestations.
RR-04	MFA not enforced for EHR system access — all clinical and administrative staff authenticate with passwords only.	Protect (PR.AC-7)	**High**	**High**	**High**	Deploy MFA across EHR and all privileged access within 30 days. Enforce phishing-resistant MFA (FIDO2) for administrative accounts.
RR-05	RBAC enforcement is weak — users retain access beyond role changes or termination; excessive	Protect (PR.AC-4)	**High**	**High**	**High**	Perform immediate access rights review. Implement automated provisioning/de-provisioning tied to HR

	permissions observed in EHR audit logs.					system. Conduct quarterly access recertification.
RR-06	ICU medical devices run end-of-life (EOL) firmware with unpatched known vulnerabilities. Vendor patch cycles not enforced or tracked.	Protect (PR.IP-12)	**High**	**High**	**High**	Establish a medical device patching program. Apply compensating controls (network isolation) for unpatchable EOL devices.
RR-07	Backup data stored unencrypted both on-premises and in cloud storage. No encryption at rest enforced for PHI backup volumes.	Protect (PR.DS-1)	**Medium**	**High**	**High**	Enforce AES-256 encryption for all backup data at rest immediately. Audit cloud storage buckets for public access exposure.
RR-08	No centralized SIEM or log aggregation platform — ICU device logs, EHR access logs, and network events are siloed with no correlation or alerting capability.	Detect (DE.CM-1)	**High**	**High**	**High**	Deploy SIEM (e.g., Splunk, Microsoft Sentinel) within 90 days. Define alert rules for anomalous EHR access, failed logins, and lateral movement.
RR-09	Incident Response Plan is outdated (last reviewed 3+ years ago) — does not address ransomware, medical device compromise, or cloud incidents. No tabletop exercises conducted.	Respond (RS.RP-1)	**High**	**High**	**High**	Revise and reapprove IRP within 30 days. Conduct ransomware tabletop exercise within 60 days.
RR-10	No documented RTO or RPO for critical ICU systems. Backup restoration tested annually only — last test failed partial EHR recovery.	Recover (RC.RP-1)	**Medium**	**High**	**High**	Define RTO/RPO for all Tier-1 systems. Increase backup restore testing to quarterly. Document and sign off recovery playbooks.
RR-11	No network segmentation between ICU biomedical device network and general hospital IT network — lateral movement from compromised endpoint to clinical devices is possible.	Protect (PR.AC-5)	**Medium**	**High**	**High**	Implement VLAN segmentation isolating ICU medical devices. Enforce firewall rules between clinical and administrative networks.
RR-12	Security awareness training is not mandatory or role-specific — clinical staff have not completed phishing simulation or security training in the past 12 months.	Protect (PR.AT-1)	**Medium**	**Medium**	**Medium**	Launch mandatory annual security awareness program. Deploy phishing simulation quarterly. Create ICU-specific training module within 90 days.
RR-13	Physical access to the ICU server room is not logged electronically — access logs are not reviewed or retained.	Protect (PR.AC-2)	**Low**	**Medium**	**Medium**	Enable electronic access log review weekly. Implement camera coverage at entry points. Retain logs for minimum 12 months.
RR-14	Cloud environment lacks defined security baseline — no enforced CIS benchmark or equivalent hardening standard applied to cloud workloads.	Protect (PR.IP-1)	**Medium**	**Medium**	**Medium**	Apply CIS Level 1 benchmarks to all cloud workloads within 90 days. Implement CSPM tooling for continuous compliance.

11	3	0
HIGH RISKS	MEDIUM RISKS	LOW RISKS

11 of 14 identified risks are rated High, indicating a security posture critically below acceptable thresholds for a regulated healthcare environment. Immediate executive escalation and resource allocation is required.

SECTION 5

Control Evaluation

Administrative | Technical | Physical

SECTION 5 — CONTROL EVALUATION

This section evaluates administrative, technical, and physical controls in the Northview Regional Medical Center ICU IT environment. Controls are assessed not merely on existence but on operational effectiveness — a control that exists on paper but is not enforced or tested provides limited risk reduction and cannot be considered adequate for a regulated healthcare environment.

Assessment Approach: Each control is evaluated against three criteria — (1) Does the control exist? (2) Is it consistently enforced? (3) Does it demonstrably reduce the risk it is designed to address? Controls are rated: Effective | Partially Effective | Weak | Non-Existent.

Control Effectiveness Summary

Category	Control	Effectiveness	Risk Ref.
Administrative	Information Security Policy	**Weak**	RR-02
Administrative	Access Control & User Access Reviews	**Weak**	RR-05
Administrative	Vendor & Third-Party Risk Management	**Non-Existent**	RR-03
Administrative	Security Awareness Training	**Partially Effective**	RR-12
Administrative	Risk Management Program	**Non-Existent**	RR-02
Technical	Multi-Factor Authentication (MFA)	**Weak**	RR-04
Technical	Encryption (Data at Rest & In Transit)	**Partially Effective**	RR-07
Technical	SIEM & Centralized Log Management	**Non-Existent**	RR-08
Technical	Network Segmentation	**Non-Existent**	RR-11
Technical	Endpoint Security & Device Patching	**Partially Effective**	RR-06
Technical	Cloud Security Configuration	**Weak**	RR-14
Physical	Server Room Physical Access Control	**Partially Effective**	RR-13
Physical	ICU Workstation & Endpoint Restrictions	**Partially Effective**	RR-05
Physical	Visitor & Contractor Physical Access Mgmt.	**Partially Effective**	RR-03

5.1 ADMINISTRATIVE CONTROLS

01 Information Security Policy

STATUS	EFFECTIVENESS
Exists — Outdated	**Weak**

FINDING

An information security policy exists but has not been reviewed or updated in over three years. It does not address cloud security, medical device governance, or ransomware response.

RECOMMENDATION

Revise and reapprove the Information Security Policy within 30 days. Establish an annual policy review cycle with CISO sign-off.

02 Access Control & User Access Reviews

STATUS	EFFECTIVENESS
Exists — Not Enforced	**Weak**

FINDING

Former employees and staff who changed roles retain active accounts with elevated EHR permissions. No automated provisioning or de-provisioning workflow is linked to HR processes.

RECOMMENDATION

Conduct immediate access rights review and revoke all orphaned accounts. Implement automated provisioning tied to HR system. Establish quarterly access recertification.

03 Vendor & Third-Party Risk Management

STATUS	EFFECTIVENESS
Non-Existent	**Non-Existent**

FINDING

No formal vendor risk management program exists. BAAs are in place but no security assessments, questionnaires, or contractual security obligations beyond the BAA have been executed.

RECOMMENDATION

Implement a Vendor Risk Management program. Require annual SOC 2 Type II reports from all PHI-handling vendors. Conduct initial risk assessments within 60 days.

04 Security Awareness Training

STATUS	EFFECTIVENESS
Exists — Incomplete	**Partially Effective**

FINDING

General training exists but is 18 months out of date, has no role-specific ICU content, and no phishing simulations. Completion rate stands at 54%.

RECOMMENDATION

Update curriculum with ICU-specific scenarios. Launch mandatory quarterly phishing simulations. Target 100% completion with manager escalation for non-compliance.

05 Risk Management Program

STATUS	EFFECTIVENESS

Non-Existent	Non-Existent

FINDING

No formal enterprise-wide risk management program. Risks are identified informally and addressed reactively. No risk register, no risk appetite statement, no risk owner accountability.

RECOMMENDATION

Establish a formal GRC risk management program. Appoint Risk Owners per domain. Conduct quarterly risk reviews reported to executive leadership.

5.2 TECHNICAL CONTROLS

MFA | Encryption | SIEM / Logging | Network Segmentation | Endpoint Security | Cloud

01 Multi-Factor Authentication (MFA)

STATUS	EFFECTIVENESS
Partially Deployed	Weak

FINDING

MFA deployed for VPN and a subset of admin accounts only. Not enforced for direct EHR login or privileged administrator accounts accessing backend infrastructure.

RECOMMENDATION

Enforce MFA for all EHR access immediately. Prioritize FIDO2/hardware token for privileged accounts. Complete full rollout within 30 days.

02 Encryption (Data at Rest & In Transit)

STATUS	EFFECTIVENESS
Partially Deployed	Partially Effective

FINDING

TLS 1.2/1.3 enforced in transit — effective. However, backup volumes stored on-premises and in cloud are not encrypted at rest, creating significant PHI exposure.

RECOMMENDATION

Enforce AES-256 encryption for all backup volumes immediately. Audit cloud storage for unencrypted volumes and public access.

03 SIEM & Centralized Log Management

STATUS	EFFECTIVENESS
Non-Existent	Non-Existent

FINDING

No SIEM or log aggregation platform. All logs are siloed with no correlation, alerting, or retention governance. No real-time threat detection capability exists.

RECOMMENDATION

Deploy SIEM within 90 days. Define alert rules for anomalous EHR access and lateral movement. Establish log retention aligned to HIPAA (6 years minimum).

04 Network Segmentation

STATUS	EFFECTIVENESS
Non-Existent in ICU Environment	Non-Existent

FINDING

ICU biomedical device network is not segmented from the general hospital IT network. A compromised administrative endpoint has an unobstructed path to clinical devices. Violates NIST SP 800-82 guidance.

RECOMMENDATION

Implement VLAN-based network segmentation isolating ICU devices immediately. Deploy firewall rules restricting all non-essential inter-VLAN communication.

05 Endpoint Security & Device Patching

STATUS	EFFECTIVENESS
Exists — Inconsistently Applied	**Partially Effective**

FINDING

EDR deployed on ~70% of administrative workstations. ICU medical devices excluded due to vendor compatibility. Medical device patching is ad hoc with no formal schedule or SLA.

RECOMMENDATION

Establish formal medical device patching program. Implement compensating controls for EOL devices. Achieve full EDR coverage within 60 days.

06 Cloud Security Configuration

STATUS	EFFECTIVENESS
Exists — No Baseline Enforced	**Weak**

FINDING

Hybrid cloud environment with no enforced CIS Benchmark or hardening standard. No CSPM tooling. Misconfigured cloud resources represent a growing attack surface.

RECOMMENDATION

Apply CIS Level 1 Benchmark to all cloud workloads within 90 days. Implement CSPM tooling for continuous compliance.

5.3 PHYSICAL CONTROLS

Server Room Access | ICU Workstation Restrictions | Visitor & Contractor Management

01 Server Room Physical Access Control

STATUS	EFFECTIVENESS
Exists — Logs Not Reviewed	**Partially Effective**

FINDING

Key card access is in place as a preventive control. However, access logs are not reviewed on schedule, and no automated alerting exists for anomalous access events.

RECOMMENDATION

Establish weekly server room access log reviews. Configure alerts for after-hours access. Install camera coverage and retain footage for 90 days minimum.

02 ICU Workstation & Endpoint Restrictions

STATUS	EFFECTIVENESS
Exists — Inconsistently Enforced	**Partially Effective**

FINDING

USB restrictions and session timeouts configured but inconsistently enforced — workstations are frequently left logged in between shifts, and some timeout policies have been locally overridden.

RECOMMENDATION

Enforce session timeout policies centrally via Group Policy, preventing local override. Deploy proximity-based authentication on ICU workstations.

03 Visitor & Contractor Physical Access Mgmt.

STATUS	EFFECTIVENESS
Exists — Informal	**Partially Effective**

FINDING

Manual sign-in process exists but vendor access to server infrastructure areas is not formally documented. No contractor background screening verification process.

RECOMMENDATION

Implement formal contractor access management with documented scope, escort assignment, and completion sign-off. Require background screening for all technical personnel.

Section Conclusion: No evaluated control achieved an Effective rating. The most critical gaps — absent SIEM capability, unenforced MFA, unencrypted backups, and missing network segmentation — represent conditions that would be cited as significant deficiencies in any regulatory audit and must be remediated immediately.

SECTION 6

Regulatory & Compliance

HIPAA | Breach Notification | HITRUST | PCI DSS | PIPEDA

SECTION 6 — REGULATORY & COMPLIANCE CONSIDERATIONS

Northview Regional Medical Center operates as a Covered Entity under HIPAA and is subject to the full obligations of the HIPAA Privacy Rule, Security Rule, and Breach Notification Rule. This section maps key assessment findings to their corresponding regulatory requirements and identifies areas of material compliance exposure.

HIPAA SECURITY RULE EXPOSURE

Primary Regulatory Framework — 45 CFR Parts 160 and 164

6.1 HIPAA Security Rule Finding Mapping

HIPAA Standard	Requirement	Assessment Finding	Compliance Status
§164.308(a)(1) — Security Management Process	Risk analysis and risk management program required	No formal risk register or risk management program exists	**Non-Compliant**
§164.308(a)(3) — Workforce Access Mgmt.	Procedures for granting and revoking access to ePHI	Orphaned accounts active; no formal de-provisioning process	**Non-Compliant**
§164.308(a)(5) — Security Awareness Training	Regular security training for all workforce members	Training incomplete; 54% completion rate; no phishing simulation	**Partially Compliant**
§164.308(a)(6) — Incident Response	Identify and respond to suspected security incidents	IRP outdated; no tested response capability for ransomware	**Non-Compliant**
§164.308(a)(7) — Contingency Planning	Data backup plan, DR plan, and emergency mode operations	No defined RTO/RPO; last backup restoration test partially failed	**Non-Compliant**
§164.310(a)(1) — Facility Access Controls	Limit physical access to ePHI systems	Server room access logs not reviewed; camera coverage absent	**Partially Compliant**
§164.312(a)(1) — Access Control	Assign unique user IDs; implement automatic logoff	MFA absent for EHR; session timeouts locally overridden	**Non-Compliant**
§164.312(a)(2)(iv) — Encryption & Decryption	Mechanism to encrypt and decrypt ePHI	Backup volumes storing ePHI not encrypted at rest	**Non-Compliant**
§164.312(b) — Audit Controls	Hardware/software activity in systems containing ePHI	No SIEM; EHR access logs not monitored or reviewed	**Non-Compliant**

§164.312(e)(1) — Transmission Security	Guard against unauthorized access during ePHI transmission	TLS 1.2/1.3 enforced for data in transit — compliant	**Compliant**

1	2	7
COMPLIANT	PARTIALLY COMPLIANT	NON-COMPLIANT

6.2 Breach Notification Rule Exposure

Under the HIPAA Breach Notification Rule (45 CFR §164.400–414), the hospital must notify affected individuals, the Secretary of HHS, and potentially media outlets in the event of a breach of unsecured ePHI. The following conditions create material breach notification risk:

- Unencrypted backup volumes containing ePHI — a lost or stolen backup drive constitutes a reportable breach with no encryption safe harbour available.
- Absent SIEM and log monitoring — the hospital cannot confirm whether a breach has or has not already occurred, creating potential liability for historical unreported breaches.
- Orphaned accounts with active EHR access — unauthorized access by former employees could trigger breach notification obligations if ePHI was accessed.
- Outdated Incident Response Plan — failure to execute a compliant breach response within the 60-day notification window is itself a HIPAA violation.

HIPAA Penalty Exposure: OCR enforcement penalties range from $100 to $50,000 per violation, with an annual cap of $1.9 million per violation category. Given the number and severity of non-compliant findings, the organization faces potential multi-category exposure. The combination of absent risk management, unencrypted ePHI backups, and failed access controls represents the profile most commonly cited in OCR enforcement actions.

6.3 Additional Applicable Standards & Frameworks

Framework / Standard	Applicability	Current Status
NIST SP 800-66r2	NIST guidance for implementing HIPAA Security Rule safeguards in healthcare organizations. Used as a reference throughout this assessment.	*Referenced — Not Formally Adopted*
NIST SP 800-82r3	NIST guide for securing industrial control systems and medical devices. Directly applicable to ICU biomedical device environment.	*Not Adopted — Gap Identified*
HITRUST CSF	Comprehensive healthcare-specific security framework mapping to HIPAA, NIST, and other standards. Provides certification pathway.	*Not Pursued — Recommended (Phase 3)*
PCI DSS v4.0	Applicable to payment card data handled through the billing vendor relationship. Hospital PCI scope should be formally defined.	*Scope Not Defined — Review Required*
PIPEDA / Ontario PHIPA	Canadian privacy legislation applicable if the hospital serves Ontario residents or operates under Ontario jurisdiction.	*Review Required — Legal Counsel Advised*

SECTION 7

Maturity Assessment

Overall Rating: Level 1 — Ad Hoc | Score: 1.2 / 5.0

SECTION 7 — MATURITY ASSESSMENT

The maturity assessment rates the organization's overall cybersecurity governance posture using a five-level maturity scale aligned to the CMMI framework, applied through the lens of the NIST CSF core functions. Maturity ratings reflect the operational consistency, documentation quality, enforcement effectiveness, and improvement capability of controls — not merely their existence.

7.1 Maturity Scale Reference

Level	Label	Description
1	Ad Hoc	Controls are absent or performed inconsistently without documented processes. Actions are reactive and individual-dependent.
2	Developing	Some controls exist and are partially documented. Processes are inconsistently applied. Awareness exists but execution is unreliable.
3	Defined	Controls are documented, approved, and consistently applied. Processes are standardized and repeatable.
4	Managed	Controls are measured, monitored, and reported. Metrics and KPIs drive decision-making.
5	Optimized	Continuous improvement is embedded. Controls adapt proactively to emerging threats. Leading security practices demonstrated.

7.2 Maturity Ratings by NIST CSF Function

NIST Function	Rating	Level	Rationale
IDENTIFY	1/5	Ad Hoc	No asset inventory, no risk register, no vendor risk program. The organization cannot identify what it needs to protect. Risk management is entirely reactive with no documented process or ownership structure.
PROTECT	2/5	Developing	Some protective controls exist (key card access, partial MFA, EDR on 70% of workstations, TLS in transit) but are inconsistently applied. No baseline standard established. Controls are present in some areas and absent in others with no unifying policy framework.
DETECT	1/5	Ad Hoc	No SIEM, no centralized logging, no alert capability, no anomaly detection. The hospital has no real-time visibility into its own environment. This is the most critical maturity gap — an organization that cannot detect threats cannot respond to them.
RESPOND	1/5	Ad Hoc	An IRP exists on paper but is materially outdated, untested, and does not address the current threat landscape. No tabletop exercises conducted. No defined escalation paths or communication protocols exist for a live incident.

RECOVER	**1/5**	**Ad Hoc**	No documented RTO/RPO. Backup testing is annual and the last test resulted in partial failure. No recovery playbooks exist for ransomware or cloud failure scenarios. Recovery capability has not been validated.

7.3 Overall Maturity Rating

OVERALL MATURITY RATING: LEVEL 1 — AD HOC

Average Score: 1.2 / 5.0 | Four of five NIST functions rated Level 1

An overall maturity rating of Level 1 — Ad Hoc indicates that cybersecurity controls at Northview Regional Medical Center are largely undefined, inconsistently applied, and operationally unreliable. This is not atypical for regional healthcare organizations that have not made deliberate, sustained investments in cybersecurity governance — however, given the regulatory environment and patient safety implications of the ICU context, it represents an unacceptable baseline that requires urgent executive action.

7.4 Target Maturity State & Timeline

NIST Function	Current State	Target (12 Months)	Key Enablers
IDENTIFY	**Level 1 — Ad Hoc**	**Level 3 — Defined**	Asset inventory (CMDB), formal risk register, vendor risk assessments
PROTECT	**Level 2 — Developing**	**Level 3 — Defined**	MFA enforcement, RBAC remediation, network segmentation, encryption baseline
DETECT	**Level 1 — Ad Hoc**	**Level 2 — Developing**	SIEM deployment, centralized logging, initial alert rule set
RESPOND	**Level 1 — Ad Hoc**	**Level 2 — Developing**	Revised IRP, tabletop exercise, defined escalation paths
RECOVER	**Level 1 — Ad Hoc**	**Level 2 — Developing**	Defined RTO/RPO, quarterly backup testing, recovery playbooks

Maturity Improvement Note: Moving from Level 1 to Level 3 across all NIST functions within 12 months is an aggressive but achievable target with full executive sponsorship and adequate resource allocation. Reaching Level 4 (Managed) or Level 5 (Optimized) is a 2–3 year programme investment, not a one-year sprint.

SECTION 8

Remediation Roadmap

Phase 1: 0–30 Days | Phase 2: 1–3 Months | Phase 3: 6–12 Months

SECTION 8 — REMEDIATION ROADMAP

The following phased remediation roadmap translates findings from this GRC assessment into a structured, prioritized action plan. Remediation items are organized across three phases based on risk severity, implementation complexity, and business impact. Each item includes a risk reference, accountable owner, estimated effort, business impact rationale, and implementation steps.

> *Prioritization Principle: Items are prioritized by patient safety risk, HIPAA exposure, and likelihood of exploitation — not ease of implementation. Quick wins that do not address critical risks are deprioritized in favour of high-impact controls, even where those controls require greater effort.*

Remediation Summary Overview

ID	Action	Phase	Priority	Effort	Risk Ref.
P1-01	Enforce MFA on EHR System — All Users	Phase 1 (0–30 Days)	Critical	Medium	RR-04
P1-02	Emergency Access Rights Review & Orphaned Account Remediation	Phase 1 (0–30 Days)	Critical	Medium	RR-05
P1-03	Revise & Reapprove Incident Response Plan (IRP)	Phase 1 (0–30 Days)	Critical	Medium	RR-09
P1-04	Implement Network Segmentation — ICU Device Isolation	Phase 1 (0–30 Days)	Critical	High	RR-11
P1-05	Encrypt All PHI Backup Volumes at Rest	Phase 1 (0–30 Days)	Critical	Medium	RR-07
P1-06	Establish Formal Risk Register & Assign Risk Owners	Phase 1 (0–30 Days)	Critical	Low	RR-02
P2-01	Deploy SIEM & Centralized Log Management	Phase 2 (1–3 Months)	High	High	RR-08
P2-02	Launch Vendor Risk Management Program	Phase 2 (1–3 Months)	High	Medium	RR-03
P2-03	Medical Device Patching Program & EOL Remediation	Phase 2 (1–3 Months)	High	High	RR-06
P2-04	Define RTO/RPO & Conduct Backup Restoration Test	Phase 2 (1–3 Months)	High	Medium	RR-10
P2-05	Conduct Ransomware Tabletop Exercise	Phase 2 (1–3 Months)	High	Low	RR-09
P2-06	Apply Cloud Security Baseline (CIS Benchmark)	Phase 2 (1–3 Months)	High	Medium	RR-14

P3-01	Establish Enterprise GRC Program & Governance Committee	**Phase 3 (6–12 Months)**	**Medium**	High	RR-02
P3-02	Launch Role-Based Security Awareness Program	**Phase 3 (6–12 Months)**	**Medium**	Medium	RR-12
P3-03	Implement 24/7 SOC Monitoring & Threat Hunting Capability	**Phase 3 (6–12 Months)**	**Medium**	High	RR-08
P3-04	Develop & Test Full Business Continuity Plan (BCP)	**Phase 3 (6–12 Months)**	**Medium**	High	RR-10
P3-05	Achieve HITRUST CSF Certification or Equivalent	**Phase 3 (6–12 Months)**	**Low**	High	RR-03

Total items: 17 | Phase 1 (Critical): 6 | Phase 2 (Significant): 6 | Phase 3 (Strategic): 5

PHASE 1 — CRITICAL FIXES

0 – 30 Days | 6 Action Items | Executive Escalation Required

Phase 1 addresses the highest-severity risks representing immediate threats to patient safety, PHI confidentiality, and HIPAA compliance. These items require executive authorization, dedicated resource allocation, and daily progress tracking.

P1-01 Enforce MFA on EHR System — All Users

OWNER	PRIORITY	ESTIMATED EFFORT
IT Security / CIO	**Critical**	**Medium**

BUSINESS IMPACT

Eliminates the highest-likelihood attack vector for unauthorized PHI access. Addresses HIPAA §164.312(d). Reduces credential-based attack risk by an estimated 99% for covered accounts.

IMPLEMENTATION STEPS

1. Audit all EHR user accounts and identify MFA enrolment gaps. 2. Deploy MFA enforcement policy. 3. Prioritize FIDO2/hardware tokens for privileged accounts. 4. Communicate rollout to clinical staff with training support.

P1-02 Emergency Access Rights Review & Orphaned Account Remediation

OWNER	PRIORITY	ESTIMATED EFFORT
IT Security / HR	**Critical**	**Medium**

BUSINESS IMPACT

Removes unauthorized access pathways from former employees and over-privileged users. Required under HIPAA §164.308(a)(3) — Workforce Access Management.

IMPLEMENTATION STEPS

1. Pull full EHR and Active Directory user list. 2. Cross-reference against HR roster — flag all non-active accounts. 3. Disable all orphaned accounts immediately. 4. Right-size permissions for role-change accounts. 5. Document all changes for audit trail.

P1-03 Revise & Reapprove Incident Response Plan (IRP)

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / IT Security	**Critical**	**Medium**

BUSINESS IMPACT

An untested, outdated IRP in a ransomware event leads to extended downtime and regulatory notification failures. HIPAA requires notification within 60 days — a plan must exist and be executable.

IMPLEMENTATION STEPS

1. Gap analysis of current IRP against NIST SP 800-61r2. 2. Add ransomware, cloud incident, and medical device playbooks. 3. Define escalation paths and regulatory notification timelines. 4. Obtain CISO and legal sign-off.

P1-04 Implement Network Segmentation — ICU Device Isolation

OWNER	PRIORITY	ESTIMATED EFFORT
Network Engineering / IT Security	Critical	High

BUSINESS IMPACT

Eliminates lateral movement path from hospital IT network to ICU clinical devices. Ransomware on any administrative endpoint currently has an unobstructed path to ventilators and cardiac monitors.

IMPLEMENTATION STEPS

1. Map current topology and identify all ICU device IP ranges. 2. Design VLAN architecture separating clinical device network. 3. Configure firewall rules — deny all non-essential inter-VLAN traffic. 4. Validate segmentation with network scan.

P1-05 Encrypt All PHI Backup Volumes at Rest

OWNER	PRIORITY	ESTIMATED EFFORT
IT Infrastructure / CISO	Critical	Medium

BUSINESS IMPACT

Unencrypted PHI backups are a reportable HIPAA breach if lost or accessed without authorization. Encryption at rest is required under HIPAA §164.312(a)(2)(iv). Eliminates a direct compliance liability.

IMPLEMENTATION STEPS

1. Inventory all backup volumes — on-premises and cloud. 2. Enable AES-256 encryption on all identified volumes. 3. Audit cloud storage buckets for public access. 4. Update backup policy to mandate encryption as baseline.

P1-06 Establish Formal Risk Register & Assign Risk Owners

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / Risk Management	Critical	Low

BUSINESS IMPACT

Without a risk register, there is no documented accountability for identified risks. This foundational governance gap will be cited by any regulator or external auditor.

IMPLEMENTATION STEPS

1. Formally adopt the risk register produced in this assessment. 2. Assign named Risk Owners for each risk. 3. Schedule first quarterly risk review. 4. Present to CISO and executive leadership for sign-off.

PHASE 2 — SIGNIFICANT IMPROVEMENTS

1 – 3 Months | 6 Action Items | Project Planning Required

Phase 2 addresses significant control gaps that represent material risk if left unresolved beyond 90 days. These items require project planning, budget allocation, and cross-functional coordination.

P2-01 Deploy SIEM & Centralized Log Management

OWNER	PRIORITY	ESTIMATED EFFORT
IT Security / SOC	High	High

BUSINESS IMPACT

Without SIEM, the hospital has zero real-time threat detection capability. Average dwell time for a healthcare breach without detection tooling exceeds 200 days.

IMPLEMENTATION STEPS

1. Issue RFP for SIEM platform. 2. Define log source inventory. 3. Deploy SIEM and onboard log sources in priority order. 4. Define initial correlation rules. 5. Establish 24/7 alert triage process.

P2-02 Launch Vendor Risk Management Program

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / Procurement / Legal	High	Medium

BUSINESS IMPACT

Lab and billing vendors process PHI on behalf of the hospital. A vendor breach is the hospital's breach under HIPAA. Without assessments, PHI cannot be confirmed as protected beyond the hospital's perimeter.

IMPLEMENTATION STEPS

1. Develop Vendor Risk Assessment questionnaire (NIST SP 800-171 aligned). 2. Assess all Tier-1 vendors. 3. Require SOC 2 Type II from all PHI-handling vendors. 4. Update contracts with security addenda.

P2-03 Medical Device Patching Program & EOL Remediation

OWNER	PRIORITY	ESTIMATED EFFORT
Biomedical Engineering / IT Security	High	High

BUSINESS IMPACT

Unpatched medical devices with documented CVEs represent a patient safety risk. A compromised infusion pump or ventilator could result in direct patient harm.

IMPLEMENTATION STEPS

1. Inventory all ICU devices with current firmware versions. 2. Cross-reference against CVE database. 3. Coordinate with manufacturers on available patches. 4. Apply patches per manufacturer guidance. 5. Isolate and plan replacement for EOL devices.

P2-04 Define RTO/RPO & Conduct Backup Restoration Test

OWNER	PRIORITY	ESTIMATED EFFORT
IT Infrastructure / Business Continuity	High	Medium

BUSINESS IMPACT

Without defined RTO/RPO and validated recovery capability, the hospital cannot make informed decisions about acceptable downtime. The ICU environment has zero tolerance for extended outages.

IMPLEMENTATION STEPS

1. Convene stakeholders to define RTO/RPO for each Tier-1 system. 2. Document targets in Business Continuity Plan. 3. Execute full backup restoration test for EHR. 4. Move to quarterly backup restoration cadence.

P2-05 Conduct Ransomware Tabletop Exercise

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / IT Security / Clinical Ops	High	Low

BUSINESS IMPACT

An untested IRP is operationally equivalent to no IRP. A tabletop exercise validates whether staff know their roles and identifies communication gaps before a real event occurs.

IMPLEMENTATION STEPS

1. Develop ransomware scenario script targeting ICU environment. 2. Invite all response team members. 3. Facilitate 3-hour tabletop exercise. 4. Document lessons learned. 5. Update IRP based on findings.

P2-06 Apply Cloud Security Baseline (CIS Benchmark)

OWNER	PRIORITY	ESTIMATED EFFORT
IT Infrastructure / Cloud Engineering	High	Medium

BUSINESS IMPACT

Misconfigured cloud resources are one of the leading causes of healthcare data breaches. Enforcing a hardening baseline eliminates a class of vulnerabilities preventable through configuration alone.

IMPLEMENTATION STEPS

1. Run CIS Benchmark assessment against current cloud environment. 2. Identify all non-compliant configurations. 3. Remediate in priority order. 4. Implement CSPM tooling for continuous compliance.

PHASE 3 — STRATEGIC MATURITY

6 – 12 Months | 5 Action Items | Long-Term Programme Investment

Phase 3 transitions the organization from reactive remediation to proactive governance maturity, building the sustainable security program infrastructure needed for continuous improvement over the long term.

P3-01 Establish Enterprise GRC Program & Governance Committee

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / Executive Leadership	Medium	High

BUSINESS IMPACT

Elevates cybersecurity from an IT function to an enterprise governance function, ensuring risk decisions are made at the appropriate level with executive accountability.

IMPLEMENTATION STEPS

1. Define GRC program charter. 2. Establish GRC Committee with CISO, CFO, CMO, Legal. 3. Implement GRC platform. 4. Integrate GRC reporting into board quarterly cycle.

P3-02 Launch Role-Based Security Awareness Program

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / HR / Clinical Education	Medium	Medium

BUSINESS IMPACT

Role-specific, scenario-based training for ICU staff measurably reduces phishing susceptibility and improves security hygiene among the primary human attack surface.

IMPLEMENTATION STEPS

1. Segment staff by role cohort. 2. Develop ICU-specific training modules. 3. Deploy quarterly phishing simulations. 4. Track completion rates monthly.

P3-03 Implement 24/7 SOC Monitoring & Threat Hunting Capability

OWNER	PRIORITY	ESTIMATED EFFORT
IT Security / CISO	Medium	High

BUSINESS IMPACT

A deployed SIEM without active monitoring is insufficient. Most ransomware deployments occur outside business hours — a SOC capability completes the Detect-to-Respond loop.

IMPLEMENTATION STEPS

1. Evaluate internal SOC vs. MSSP. 2. Select and onboard SOC capability. 3. Define escalation procedures and SLAs. 4. Tune SIEM rules based on 90 days of live data.

P3-04 Develop & Test Full Business Continuity Plan (BCP)

OWNER	PRIORITY	ESTIMATED EFFORT
IT Infrastructure / Clinical Ops	Medium	High

BUSINESS IMPACT

A comprehensive BCP ensures critical patient care can be sustained during any disruption, including manual downtime procedures for ICU staff during extended EHR outages.

IMPLEMENTATION STEPS

1. Conduct Business Impact Analysis across all departments. 2. Develop BCP documentation. 3. Conduct full BCP exercise simulating 72-hour EHR outage. 4. Present to board and cybersecurity insurer.

P3-05 Achieve HITRUST CSF Certification or Equivalent

OWNER	PRIORITY	ESTIMATED EFFORT
CISO / Compliance	Low	High

BUSINESS IMPACT

HITRUST certification provides independently verified security maturity to regulators, insurers, and business partners, and significantly reduces HIPAA penalty risk in the event of a breach.

IMPLEMENTATION STEPS

1. Conduct HITRUST readiness assessment. 2. Remediate all identified gaps. 3. Engage HITRUST-authorized assessor for formal assessment. 4. Achieve and maintain HITRUST CSF Certified status.

Budget & Resource Considerations

Phase	Est. Investment Range	Primary Cost Drivers	Risk if Deferred
Phase 1 (0–30 Days)	$15,000 – $40,000	MFA licensing, network engineering labour, IRP consulting	Regulatory breach, ransomware event, HIPAA penalty (up to $1.9M per violation category)
Phase 2 (1–3 Months)	$80,000 – $180,000	SIEM platform, medical device patching, vendor assessment programme	Undetected breach, device compromise, audit findings, insurer non-renewal
Phase 3 (6–12 Months)	$150,000 – $350,000	GRC platform, SOC capability, BCP development, HITRUST certification	Stalled maturity, inability to obtain cyber insurance, recurring audit findings

Budget Prioritization Guidance: If budget is constrained, the following Phase 1 items must be protected at all costs: MFA enforcement (P1-01), network segmentation (P1-04), and backup encryption (P1-05). These three items address the conditions most likely to result in a catastrophic, unrecoverable event — ransomware propagating across the ICU clinical network with unrecoverable PHI.